

Unauthorised Use of Generative AI Tools in Production response

AI Security · **Critical** severity · SOC IR Playbook

Incident type	Policy Violation / Data Exposure Risk
Severity	Critical
Priority	High
Detection sources	DLP, CASB, SIEM, Proxy Logs, Endpoint Telemetry, IT Governance Alerts, Security Awareness Reports

Scenario

An employee or system uses a generative AI tool in a production environment-either by pasting sensitive code, data or configuration into an AI prompt or by integrating an AI assistant into a live application-without formal approval or proper security evaluation.

MITRE ATT&CK

T1087.003, T1203, T1567.002

Preparation

Implement acceptable use policies Clearly define boundaries for AI use across environments Monitor AI platform access Log and alert on interactions with generative AI URLs (e.g., openai.com, bard.google.com) Use DLP and CASB tools Monitor for sensitive data input into AI tools or external APIs Enforce browser controls and blocking Limit AI tool usage from high-sensitivity zones (e.g., finance, dev, prod) Conduct user training On generative AI risks and organisational compliance requirements

Detection & Analysis

Detect unauthorised use DLP, CASB or proxy log alerts showing data pasted to AI tool or plugin usage in prod Identify user or system Correlate logs with source IP, user ID, browser agent or application logs Review transmitted data Determine if code, credentials, PII or intellectual property was included Assess context of usage Accidental misuse vs intentional automation or shadow AI integration

Containment

Block further access Disable user access to the AI tool or integration via firewall, proxy or CASB policy Quarantine affected systems If AI integration was in active code or service Alert user and management Notify stakeholders and freeze further use during investigation Capture forensic snapshot Of prompt history, browser activity and transferred data (where possible)

Eradication

Remove AI integration From production services, scripts or pipelines if embedded Revoke any API tokens used In unauthorised AI integrations (e.g., OpenAI API keys) Rotate exposed secrets If credentials were pasted or stored by AI Clean up policy violations Update configurations to remove AI-related exceptions or allowlists if misused

Recovery

Restore access under policy Only after users acknowledge acceptable use terms or AI plugins are audited and approved Validate codebase and production changes Ensure no unauthorised automation remains Implement AI governance checks Introduce review workflows for AI-related tool usage and integrations Resume operations Once security and compliance teams confirm risk is mitigated

Lessons Learned & Reporting

Conduct root cause analysis Why and how the AI tool was accessed or integrated Update monitoring controls Add detections for new AI platforms or browser extensions Improve internal education Add AI-specific scenarios to cybersecurity awareness programs Report if required If IP or regulated data was exposed (e.g., GDPR, HIPAA, PDPA compliance) Document incident Include users involved, data accessed, remediation timeline and preventive steps

Tools typically involved

DLP (e.g., Microsoft Purview, Symantec, Forcepoint); CASB (e.g., Netskope, Microsoft Defender for Cloud Apps); SIEM (e.g., Splunk, Sentinel, QRadar); Endpoint Detection and Response (e.g., CrowdStrike, Cortex XDR); Proxy/Firewall Logs (e.g., Zscaler, Palo Alto, Fortinet); Browser control tools (e.g., Chrome enterprise policies, Edge management); Generative AI access logs (if integrated with enterprise identity systems)

Success metrics (SLA targets)

Detection Time <10 minutes from data transfer or plugin use Containment Time <30 minutes for access revocation Risk Assessment Completion <24 hours from incident start Policy Re-acknowledgment Rate 100% of involved users within 3 days Compliance Review Timeframe Within 7 days of incident resolution